

DDTA – Facial Access Project Documentation

Documentation-Driven Threat Analysis

Working document – R24 – MacroRequirements completi

1 Project Problem Framing

Il progetto affronta il problema di controllare l'accesso a un'area fisica riservata, determinando se una persona che si presenta a un punto di accesso possa entrare e rendendo possibile l'apertura del varco solo quando le condizioni di accesso previste dall'organizzazione risultano soddisfatte.

Rientrano nel problema la gestione delle condizioni che determinano chi può accedere, la verifica della persona che si presenta, la decisione relativa all'accesso e le conseguenze dell'uso di informazioni personali o biometriche necessarie al processo.

Base Analysis

Il framing definisce il confine del problema. La BA inline riportata nelle pagine successive ricostruisce esclusivamente significati supportati dai campi MR ormai compilati fino a **depends0n**; eventuali elementi ancora non materializzati restano diagnostici da riesaminare nel pass BA completo.

2 MacroRequirements – campi completi con Base Analysis inline

Convenzione di lettura. La colonna sinistra contiene la documentazione MR in costruzione. La colonna destra mostra la Base Analysis materializzabile o il delta diagnostico osservabile dal testo affiancato. In questo checkpoint sperimentale, ***<CanonicalName>** indica un BAREferent candidato **BEHAVIORAL**; **#<CanonicalName>** indica un BAREferent candidato **NON-BEHAVIORAL**; **@<semanticOperatorKey>** indica un operatore BA2. I marcatori *****, **#** e **@** non fanno parte del nome canonico o della chiave semantica. La distinzione BEHAVIORAL/NON-BEHAVIORAL resta un **pressure point R24 PENDING_REVIEW**, non una modifica già accettata del contratto BA.

MR-0001 – Controllo dell'accesso all'area riservata

ID

MR-0001

Lifecycle

current

Intent

Consentire a `*<ControlledAreaAccess>` di determinare se un tentativo di accesso all'area riservata possa essere consentito, usando `#<IdentityVerificationEvidence>` e `#<AccessAuthorizationState>` per `@<produce>` `#<AccessDecision>` coerente con le condizioni stabilite dall'organizzazione.

Context

Nel controllo di un accesso, la decisione relativa al tentativo deve essere formulata tenendo insieme due informazioni concettualmente distinte: l'evidenza relativa alla verifica della persona che si presenta e lo stato di autorizzazione associato all'identità governata rilevante. `*<ControlledAreaAccess>` costituisce il punto del problema in cui tali informazioni assumono significato congiunto ai fini della decisione di accesso.

Stakeholders

- persone che si presentano al punto di accesso;
- organizzazione responsabile dell'area riservata e delle condizioni di accesso.

Scope

Rientrano nella responsabilità il controllo del tentativo di accesso, la determinazione dell'esito sulla base delle condizioni necessarie e il fatto che l'accesso possa essere reso possibile quando tale esito lo consente.

Non rientrano nella responsabilità la definizione e il mantenimento delle autorizzazioni di accesso, la gestione delle identità, la verifica della persona che si presenta al punto di accesso né le scelte tecniche con cui la decisione o l'apertura del varco vengono realizzate.

Assumptions (optional)

Nessuna assunzione macro esplicita.

Constraints (optional)

Nessun vincolo macro esplicito.

dependsOn

- MR-0002;
- MR-0003.

Base Analysis

BAReferent già presenti

`*<ControlledAreaAccess>`

`#<IdentityVerificationEvidence>`

`#<AccessAuthorizationState>`

`#<AccessDecision>`

P06 – `@<produce>`

actor → `*<ControlledAreaAccess>`

input →

`#<IdentityVerificationEvidence>`

input →

`#<AccessAuthorizationState>`

result → `#<AccessDecision>`

originState: GROUNDED

reviewState: PENDING_REVIEW

P07 – `@<dependOn>`

dependent →

`*<ControlledAreaAccess>`

prerequisite →

`*<AccessAuthorizationManagement>`

prerequisite →

`*<IdentityVerification>`

originState: GROUNDED

reviewState: PENDING_REVIEW

Delta dei nuovi campi

Context stabilizza l'interpretazione di P06 senza aggiungere referent.

Stakeholders non produce delta strutturale al livello corrente. Scope chiarisce il confine della responsabilità e rende osservabile il consumo di risultati prodotti da altri MR senza inglobarne le responsabilità.

OPEN per il pass BA completo

Lo Scope include anche l'effetto di rendere possibile l'accesso quando l'esito lo consente. Questo significato governato non è ancora rappresentato separatamente da P06: non viene inventato qui un nuovo referent o operatore; resta da riesaminare nel pass BA completo.

MR-0002 – Gestione delle autorizzazioni di accesso

ID

MR-0002

Lifecycle

current

Intent

Consentire a `*<AccessAuthorizationManagement>` di stabilire e mantenere nel tempo lo stato delle autorizzazioni di accesso definite dall'organizzazione, di `@<correlate>` `#<AccessAuthorizationState>` con la relativa `#<GovernedIdentity>` e di `@<produce>` `#<AccessAuthorizationState>` aggiornato e utilizzabile da `*<ControlledAreaAccess>`.

Context

L'autorizzazione di accesso esprime una condizione attribuita dall'organizzazione a una `#<GovernedIdentity>` e rilevante per stabilire se l'accesso possa essere consentito. Tale condizione può essere mantenuta nel tempo indipendentemente dalla presenza di una persona al punto di accesso e viene rappresentata, per il processo di accesso, mediante `#<AccessAuthorizationState>`.

Stakeholders

- organizzazione e soggetti da essa delegati alla gestione delle autorizzazioni;
- persone alle cui identità sono associate autorizzazioni di accesso.

Scope

Rientrano nella responsabilità la definizione e il mantenimento nel tempo delle autorizzazioni di accesso associate alle identità governate e la disponibilità dello stato di autorizzazione necessario al controllo dell'accesso.

Non rientrano nella responsabilità la gestione delle identità a cui le autorizzazioni si riferiscono, la verifica della persona che si presenta al punto di accesso, la decisione relativa al singolo tentativo di accesso né le modalità tecniche con cui le autorizzazioni vengono memorizzate, aggiornate o rese disponibili.

Assumptions (optional)

Nessuna assunzione macro esplicita.

Constraints (optional)

Nessun vincolo macro esplicito.

dependsOn

- MR-0004.

Base Analysis

BAReferent già presenti

`*<AccessAuthorizationManagement>`

`#<AccessAuthorizationState>`

`#<GovernedIdentity>`

P02 – @<correlate>

`correlatedItem →`

`#<AccessAuthorizationState>`

`correlatedItem →`

`#<GovernedIdentity>`

`correlationContext →`

`*<AccessAuthorizationManagement>`

`originState: GROUNDED`

`reviewState: PENDING_REVIEW`

P03 – @<produce>

`actor →`

`*<AccessAuthorizationManagement>`

`result →`

`#<AccessAuthorizationState>`

`originState: GROUNDED`

`reviewState: PENDING_REVIEW`

P08 – @<dependOn>

`dependent →`

`*<AccessAuthorizationManagement>`

`prerequisite →`

`*<IdentityManagement>`

`originState: GROUNDED`

`reviewState: PENDING_REVIEW`

Delta dei nuovi campi

Context stabilizza il significato temporale e identitario dello stato di autorizzazione. Stakeholders non produce delta strutturale al livello corrente. Scope conferma che MR-0002 possiede l'autorizzazione ma non ingloba identità, verifica o decisione di accesso. `dependsOn` rende governata la dipendenza diretta da MR-0004.

MR-0003 – Verifica della persona al punto di accesso

ID

MR-0003

Lifecycle

current

Intent

Consentire a *<IdentityVerification> di stabilire a quale #<GovernedIdentity> corrisponde #<PersonAtAccessPoint>, e di @<produce> #<IdentityVerificationEvidence> utilizzabile da *<ControlledAreaAccess>.

Context

Al punto di accesso, #<PersonAtAccessPoint> e #<GovernedIdentity> rappresentano significati distinti: il primo riguarda la persona che si presenta in quel momento, mentre il secondo costituisce il riferimento governato al quale la persona può essere ricondotta. *<IdentityVerification> riguarda la determinazione di questa corrispondenza e la disponibilità della relativa #<IdentityVerificationEvidence>.

Stakeholders

- persone che si presentano al punto di accesso;
- organizzazione che utilizza l'evidenza di verifica nel processo di accesso.

Scope

Rientrano nella responsabilità la verifica della persona che si presenta al punto di accesso, la determinazione della sua corrispondenza con una identità governata e la disponibilità dell'evidenza risultante necessaria al controllo dell'accesso.

Non rientrano nella responsabilità la gestione delle identità governate, la definizione o il mantenimento delle autorizzazioni di accesso, la decisione relativa al singolo tentativo di accesso né le modalità tecniche con cui la verifica viene realizzata.

Assumptions (optional)

Nessuna assunzione macro esplicita.

Constraints (optional)

Nessun vincolo macro esplicito.

dependsOn

- MR-0004.

Base Analysis

BAReferent già presenti

*<IdentityVerification>

#<GovernedIdentity>

#<PersonAtAccessPoint>

#<IdentityVerificationEvidence>

P04 – @<correlate>

correlatedItem →

#<PersonAtAccessPoint>

correlatedItem →

#<GovernedIdentity>

correlationContext →

*<IdentityVerification>

originState: GROUNDED

reviewState: PENDING_REVIEW

P05 – @<produce>

actor → *<IdentityVerification>

result →

#<IdentityVerificationEvidence>

originState: GROUNDED

reviewState: PENDING_REVIEW

P09 – @<dependOn>

dependent →

*<IdentityVerification>

prerequisite →

*<IdentityManagement>

originState: GROUNDED

reviewState: PENDING_REVIEW

Delta dei nuovi campi

Context rende esplicita la distinzione tra persona presente e identità governata e stabilizza P04.

Stakeholders non produce delta strutturale al livello corrente. Scope mantiene la verifica separata da identità, autorizzazione e decisione. dependsOn rende governata la dipendenza diretta da MR-0004.

MR-0004 – Gestione delle identità

ID

MR-0004

Lifecycle

current

Intent

Consentire a *<IdentityManagement> di @<create> e mantenere le #<GovernedIdentity> necessarie al controllo degli accessi, rendendole disponibili alle responsabilità di progetto che devono riferirsi a un'identità governata.

Context

Le diverse responsabilità coinvolte nel controllo degli accessi devono poter fare riferimento in modo coerente alle stesse identità nel tempo. *<IdentityManagement> rende disponibile questo riferimento governato attraverso #<GovernedIdentity>, permettendone il riuso nei diversi momenti in cui il progetto deve riferirsi all'identità di una persona.

Stakeholders

- organizzazione e soggetti da essa delegati alla gestione delle identità;
- persone alle quali le #<GovernedIdentity> si riferiscono.

Scope

Rientrano nella responsabilità la creazione e il mantenimento nel tempo delle identità governate necessarie al controllo degli accessi e la loro disponibilità alle altre responsabilità di progetto che devono riferirsi in modo coerente all'identità di una persona.

Non rientrano nella responsabilità la definizione o il mantenimento delle autorizzazioni di accesso associate alle identità, la verifica della persona che si presenta al punto di accesso, la decisione relativa al singolo tentativo di accesso né le modalità tecniche con cui le identità vengono rappresentate, memorizzate o gestite.

Assumptions (optional)

Nessuna assunzione macro esplicita.

Constraints (optional)

Nessun vincolo macro esplicito.

dependsOn

Nessuna dipendenza MR esplicita.

Base Analysis

BAReferent già presenti

*<IdentityManagement>

#<GovernedIdentity>

P01 – @<create>

actor → *<IdentityManagement>

created → #<GovernedIdentity>

originState: GROUNDED

reviewState: PENDING_REVIEW

Delta dei nuovi campi

Context stabilizza il ruolo di

#<GovernedIdentity> come

riferimento condiviso e riusabile.

Stakeholders non produce delta

strutturale al livello corrente. Scope

conferma che MR-0004 possiede la

gestione dell'identità ma non

autorizzazione, verifica o decisione di

accesso. Non emerge una dipendenza

MR diretta da governare.

OPEN per il pass BA completo

Intent e Scope parlano anche di

mantenimento nel tempo delle

identità. P01 rappresenta

esplicitamente @<create>, ma non

materializza ancora separatamente la

semantica di mantenimento. Nessuna

relazione viene inventata in questo

checkpoint.

3 Checkpoint del ciclo MR – campi completi

Documentazione MR completata

Per ciascun MacroRequirement sono ora stati attraversati in ordine i campi `id`, `title`, `lifecycle`, `intent`, `context`, `stakeholders`, `scope`, `assumptions`, `constraints` e `dependsOn`. I campi opzionali `assumptions` e `constraints` non hanno prodotto contenuto macro necessario nel caso di studio corrente.

Delta BA osservato dai campi successivi a Title + Intent

- **Context:** non richiede nuovi BAReferent o BAProposition; stabilizza e disambigua l'interpretazione della struttura già emersa da Title + Intent.
- **Stakeholders:** al livello corrente non richiede incremento strutturale della BA.
- **Scope:** chiarisce i confini delle responsabilità e rende diagnosticabile il riuso cross-MR senza trasformare il riuso in una relazione normativa inventata dalla BA.
- **Assumptions / Constraints:** nessun delta nel caso di studio corrente.
- **dependsOn:** introduce semantica governata di dipendenza e permette di materializzare tre nuove BAProposition con l'operatore BA2 @<dependOn>: P07, P08 e P09, senza creare nuovi BAReferent.

Cross-MR verification

Le dipendenze documentate coincidono con i collegamenti che la BA precedente poteva già segnalare come handoff cross-MR sulla base di proposition e provenance:

- MR-0001 → MR-0002: #<AccessAuthorizationState> prodotto da P03 e usato come input da P06;
- MR-0001 → MR-0003: #<IdentityVerificationEvidence> prodotto da P05 e usato come input da P06;
- MR-0002 → MR-0004: #<GovernedIdentity> creato in P01 e correlato in P02;
- MR-0003 → MR-0004: #<GovernedIdentity> creato in P01 e correlato in P04.

Questo suggerisce un diagnostico R24 deterministico da conservare: un handoff cross-MR osservabile da BA + provenance può essere segnalato come *unresolved* finché la documentazione non governa la relazione; un `dependsOn` coerente può poi risolvere la segnalazione. La BA non deve generare automaticamente `dependsOn` e un `dependsOn` privo di evidenza semantica BA deve poter essere segnalato per revisione.

Pressure point BA da conservare

La distinzione sperimentale *<CanonicalName> = BEHAVIORAL e #<CanonicalName> = NON-BEHAVIORAL continua a ricevere evidenza dai nuovi campi, ma resta **PENDING_REVIEW**. Non viene ancora deciso se debba essere espressa tramite `classify/semanticKind`, mediante una minima ridefinizione di BAReferent o soltanto come convenzione di authoring/proiezione.

OPEN prima del Gate D1 / R24-G1

Prima di dichiarare chiuso il livello MR va eseguito il pass BA completo A/B/C sull'intero set. In particolare occorre riesaminare senza inventare semantica: (1) l'effetto, ora esplicito nello Scope di MR-0001, di rendere possibile l'accesso quando l'esito lo consente; (2) la semantica di mantenimento nel tempo presente in MR-0002 e MR-0004 ma non ancora materializzata separatamente nelle proposition correnti; (3) la coerenza complessiva delle nuove P07–P09 con il contratto BA2 `dependOn`.